

Postal Address:
Box 8114
104 20 Stockholm
Website:
www.imy.se
Email:
imy@imy.se
Phone:
08-657 61 00
1(16)

Apoteket AB
Decision following supervision under the
Data Protection Regulation – Apoteket
AB

Decision of the Swedish Authority for Privacy Protection

The Swedish Authority for Privacy Protection (Integritetsskyddsmyndigheten) finds that Apoteket AB (556138-6532) has processed personal data in violation of Article 32.1 of the Data Protection Regulation by failing to implement appropriate technical and organizational measures to ensure a suitable level of security for personal data when using the analytics tool Meta-pixel during the period from January 19, 2020, to April 25, 2022.

The Swedish Authority for Privacy Protection decides, based on Articles 58.2 and 83 of the Data Protection Regulation, that Apoteket AB shall pay an administrative fine of 37,000,000 SEK.

Summary of the supervisory case

Background, etc.

On April 25, 2022, Apoteket AB (Apoteket) submitted a notification of a personal data incident to the Swedish Authority for Privacy Protection (IMY). The notification indicated that Apoteket had used Meta Platforms Ireland Limited's (Meta's) analytics tool Meta-pixel on its website www.apoteket.se (the website) to enhance advertising towards customers, thereby allowing the transfer of data regarding customers and website visitors to Meta that was not intended to be transferred. Apoteket discovered the incident through information from an external source. The incident notification was preceded by media reports that Apoteket had transferred certain data about its customers' online purchases to Meta.

IMY initiated supervision in May 2022 based on the information contained in the incident notification. The supervision has been limited to the question of whether Apoteket has taken appropriate technical and organizational measures in accordance with Article 32 of the Data Protection Regulation.

1 Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation).

Case Number:

IMY-2022-3270

Date:

2024-08-29

Swedish Authority for Privacy Protection

Case Number: IMY-2022-3270

2(16)

Date: 2024-08-29

The processing at IMY has taken place through written correspondence with Apoteket. IMY has also obtained information from Meta regarding how the Meta-pixel and its filtering mechanism work.

What Apoteket has stated

Apoteket has primarily stated the following regarding the issue under review.

Data Controller

Apoteket is the data controller concerning the implementation of the Meta-pixel (formerly Facebook pixel) and the transfer of data to Meta (formerly Facebook).

Purpose of the processing

Apoteket has used the Meta-pixel since 2017. The processing has generally been carried out for marketing purposes. The primary purpose was to measure the effectiveness of the company's marketing on Meta's social media platforms Facebook and Instagram. The secondary purpose was to market products to visitors who had visited product pages for self-care without making a purchase, in order to encourage these customers to shop at a later time. The pixel was used for the secondary purpose to a limited extent, during limited periods. On January 19, 2020, the automatic type of the Meta-pixel's advanced matching function (AAM function) was activated, which meant that more data than before would be processed. The activation of the AAM function was not necessary to fulfill the purposes of the processing. The activation of the Meta-pixel and the AAM function was carried out by individual employees without prior risk assessment, in violation of Apoteket's procedures. Apoteket became aware that data that could be considered sensitive had been shared only after media reported on it. Apoteket decided to immediately deactivate the Meta-pixel and the AAM function on April 25, 2022, after the company was made aware of the extent of the data that had been transferred.

What personal data has been transferred to Meta

The transfer to Meta has not been the same for all customers but has depended on the customer's actions on the website. Apoteket has not transferred data about customers who have declined marketing cookies. For customers who have consented to marketing cookies, the following event data has generally been transferred via the Meta-pixel:

- URL
- value (value of product or total shopping cart)
- currency (= "SEK")
- content IDs (Product ID, Apoteket's internal product number)
- content Type (= "Product")
- IP address.

Since the AAM function was activated, the following contact information has also been transferred:

- first and last name
- email address
- phone number
- personal identification number
- gender
- city
- postal code
- country.

Integrity Protection Authority

Diary Number: IMY-2022-3270

3(16)

Date: 2024-08-29

Contact information has only been transferred during completed purchases and then in hashed form, which meant that Meta could only read the information if they had corresponding information previously. Meta has since attempted to match the transferred contact information with a user ID on Facebook and then deleted it. If a customer has logged into "My Pages" with mobile BankID, the personal identification number has been transferred as it was interpreted as a phone number. The pharmacy has made an active choice not to transfer data regarding prescription items. The exclusion has occurred by ensuring that the part of the website where a customer can add a prescription item to the cart did not contain the Meta pixel. Furthermore, order lines that include prescription items have been filtered out at the time of purchase from the product data by the pharmacy's server before being transferred to Meta. If a visitor has accepted marketing cookies and

completed a purchase, information about the following products and/or product categories has been shared via the Meta pixel with the AAM function activated:

- a) self-tests and treatment for sexually transmitted diseases
- b) contraceptives and emergency contraceptive pills
- c) sex toys
- d) products for vaginal health (e.g., dry mucous membranes, menopausal symptoms, and yeast infections)
- e) products for prostate issues and urinary problems
- f) pregnancy tests, ovulation tests, and pregnancy products
- g) products for the treatment of fungal infections (e.g., athlete's foot or nail fungus)
- h) products for the treatment and management of diabetes
- i) products for the treatment of rectal issues (e.g., anal fissures and hemorrhoids)
- j) products for the treatment of stomach issues (e.g., IBS, constipation, and diarrhea)
- k) products for the treatment of migraines
- l) products for the treatment of allergies
- m) accessories for hearing aids
- n) products for the treatment of bacterial infections
- o) products for the treatment of psoriasis
- p) products for the treatment of rosacea
- q) ostomy products.

Meta is fundamentally a legitimate recipient, and all transfers of website visitors' data have not been unauthorized. What constitutes a personal data incident is the potential transfer of sensitive personal data. However, not all products in the pharmacy's range can be considered to provide information about a person's health or sex life, but only products from a so-called sensitive category in combination with a direct personal data. A person's behavior on the website does not necessarily indicate anything about the individual's health or sex life until the customer has added a sensitive product to the cart or completed a purchase of such a product. However, it is not obvious that this also says anything about the individual customer since many purchase products for others, for preventive purposes, or for a "home pharmacy." Moreover, the self-care products that the pharmacy sells certainly do not belong to the so-called sensitive category. The legal situation in this area is unclear, and it is difficult to categorically state that sensitive personal data has been transferred.

If the transfer of sensitive personal data has occurred, it has not been the pharmacy's intention. The pharmacy does have a data processing agreement with Meta, and it is not a question of an unknown recipient of the data. The transfer has not occurred in an uncontrolled manner in the sense that unauthorized persons have accessed the information through a hacking attack with obvious malicious intent. The actual risk to the registered individuals is therefore assessed as moderate. The transfer of personal identification numbers has not increased the risk for the

Swedish Data Protection Authority

Diary Number: IMY-2022-3270

4(16)

Date: 2024-08-29

registered because the data was transferred in distorted form, hashed2 with SHA256, and then deleted by Meta because the data could not be matched. The primary deficiency consists of the fact that the registered individuals have somewhat lost control over their personal data, but the actions of the Pharmacy in itself did not increase the risk for the registered individuals. It should be seen as a mitigating factor that Meta had an active signal filtering mechanism that filtered out sensitive data. The information has thus not been shared further or used by the Pharmacy or Meta. The harm to the registered individuals is therefore limited.

Scope of the Incident

At the time of the report, the incident was estimated to have affected 500,001–1,000,000 registered individuals. The Pharmacy has since stated that it is not possible to provide an exact number of the registered individuals affected by the incident. This is partly due to the fact that it is not a leak from a

register or a database that the Pharmacy has had full control and insight over, and that the transfer of data occurred directly between the user's browser and Meta. The circle of potentially affected registered individuals is influenced by several factors. The maximum number of affected individuals is 930,000. The calculation is based on the number of purchases made online during the relevant period, taking into account that a certain proportion of purchases are made by returning customers and customers who use ad blockers or have declined the use of cookies. The Pharmacy's view is that the incident only includes completed purchases and not data about a person clicking on products, adding products to the cart, or initiating payment. Nine percent of the total share of online sales during the period in which the incident occurred consisted of products that belong to the categories listed above under items a–q. Regarding the amount of transferred personal data, the Pharmacy has stated that the number of unique products for each purchase made during the period amounts to 1.41 products per customer. However, when assessing how many sensitive personal data have been transferred, it must be considered that some of the purchases have included self-care products (which do not reveal health information), were made on behalf of others, or involved multiple packages of the same product.

Technical and Organizational Security

Before the incident in question, the Pharmacy had proactive processes in place to ensure the correct handling of personal data, including thorough risk assessments and reviews by the data protection officer regarding issues related to personal data. The Pharmacy's development process includes several checkpoints to capture risks and ensure proper processing of personal data. The checkpoints consist of new solutions or features on the website being reviewed from an information security and data protection perspective (through an information analysis), an architectural perspective, and contractually (if the solution is procured), as well as code reviews before the solution goes into production on the website. The Pharmacy also conducts audits and penetration tests of the website to detect and address vulnerabilities.

In this particular case, the Pharmacy's established procedures for IT development and risk assessment were not followed by individual employees. A possible reason, which is not a defense, may have been that the functionality was very easy to activate without any actual development effort. At the time of the activation of the AAM function, administrative access in the Meta Business Manager tool was required, which two professional roles, encompassing a total of three individuals, had. According to routine, access rights to the Meta Business Manager tool, including the AAM function, are reviewed and checked regularly to ensure that

2 Hashing is a cryptographic one-way function that can be used to achieve pseudonymization, which is a possible security measure according to Article 32 of the General Data Protection Regulation, by replacing personal data with a so-called hash value. This means that the replaced personal data is not available in plaintext and that additional information is needed to identify the registered individual.

Swedish Data Protection Authority

Diary Number: IMY-2022-3270

5(16)

Date: 2024-08-29

only individuals with a need have access. No other desirable routines for review and follow-up have been established due to the activation of the pixel and the AAM function not following the Pharmacy's regular procedures.

After the Meta pixel and AAM function were deactivated, the Pharmacy engaged in a dialogue with Meta regarding data deletion. Meta has stated that data older than two years has already been deleted, but that the company cannot manually delete data from the last two years. The Pharmacy has provided general information to the data subjects about the incident, which was published on the website at the end of April and in May 2022. To address specific questions and responses from customers, an information document was prepared for the Pharmacy's employees. The Pharmacy has also taken measures to reduce the risk of similar incidents in the long term. The company has conducted an inventory and analysis of cookies and analytics tools on the website, established a professional role with overall responsibility for the marketing department to ensure compliance with rules and guidelines, and improved its governance model for information security. Employees

previously completed an annual e-training on security that includes a chapter on data protection and information security. To further enhance awareness after the incident, short e-trainings on IT and information security have been introduced.

Choice of corrective action

The Pharmacy has transferred data to Meta that should not have been shared. However, the damage has been limited. The violation has not affected the core fulfillment of the Pharmacy's obligations under Article 32 of the General Data Protection Regulation. The Pharmacy immediately reported the violation to IMY and took the measures that were possible to mitigate the consequences of the violation. These circumstances, combined with the fact that the violation occurred through negligence, indicate that this is a minor violation, and therefore it is sufficient to issue a reprimand.

Regarding the seriousness of the violation, it has only slightly hindered the effective application of Article 32 of the General Data Protection Regulation. Furthermore, the violation occurred within business operations, and the nature of the processing has therefore not posed any particular risks. There has also been no dependency relationship between the data subjects and the Pharmacy. The processing has been carried out for marketing purposes, which is not part of the Pharmacy's core business of providing prescription and over-the-counter medications. The personal data incident has indeed involved a relatively large number of data subjects, but the level of harm caused by the violation is low. The violation should at most be considered of medium severity.

There are reasons to consider how turnover is calculated within other EU legal areas, primarily competition law. This is because the majority of the Pharmacy's turnover derives from other parts of the Pharmacy's operations, such as traditional retail and healthcare and dosage businesses, than the area in which the violation occurred. According to the Commission's Guidelines for calculating fines imposed under Article 23.2 a of Regulation No. 1/2003, the basic amount for the calculation should be determined by taking into account the sales value of the goods or services that have a direct or indirect connection with the violation and that the company has sold in the relevant geographical area within the EEA. Analogously, the part of the Pharmacy's turnover that pertains to the segment of the business where the violation occurred should be considered, namely the turnover related to online sales of over-the-counter medications, self-care products, hygiene items, and skincare.

3 Council Regulation (EC) No. 1/2003 of December 16, 2002, on the implementation of the competition rules in Articles 81 and 82 of the Treaty.

Swedish Authority for Privacy Protection

Diary Number: IMY-2022-3270

6(16)

Date: 2024-08-29

There are several mitigating circumstances surrounding the violation, including the measures taken by the Pharmacy to alleviate the consequences for the data subjects, that the Pharmacy has fully cooperated with IMY, and that data has been filtered out and thus not reached Meta for further processing. The Pharmacy has also reported the incident on its own initiative to IMY. Since economic gain from the violation can be seen as an aggravating factor in the calculation of the sanction fee, the Pharmacy wishes to clarify that the increase in sales that may be linked to the use of the AAM function is virtually non-existent.

Justification of the Decision

IMY must initially determine whether the General Data Protection Regulation (GDPR) is applicable and whether IMY is the competent supervisory authority. If this is the case, IMY will examine whether the Pharmacy is the data controller and whether the company has taken appropriate security measures in accordance with Article 32 of the GDPR to protect the personal data processed through the Meta pixel, with the AAM function activated, during the period from January 19, 2020, to April 25, 2022.

IMY's Competence

Applicable Provisions

According to Article 95 of the GDPR, the GDPR shall not impose any additional obligations on natural or legal persons processing personal data for areas already covered by obligations under the so-called

ePrivacy Directive. The ePrivacy Directive has been implemented in Swedish law through the Act (2003:389) on Electronic Communication (LEK), which regulates, among other things, the collection of data through cookies.

According to Chapter 9, Section 28 of LEK, which implements Article 5.3 of the ePrivacy Directive, data may only be stored in or retrieved from a subscriber's or user's terminal equipment if the subscriber or user has access to information about the purpose of the processing and consents to it. Furthermore, it is stated that this does not prevent such storage or access that is necessary for the transmission of an electronic message via an electronic communications network or that is necessary to provide a service that the user or subscriber has explicitly requested. LEK came into force on August 22, 2022. However, during the relevant time in this case, the same requirements applied according to Chapter 6, Section 18 of the Act (2003:389) on Electronic Communication. The Swedish Post and Telecom Authority (PTS) is the supervisory authority according to LEK (Chapter 1, Section 5 of the Regulation [2022:511] on Electronic Communication).

The European Data Protection Board (EDPB) has commented on the interaction between the ePrivacy Directive and the GDPR. The opinion states, among other things, that the national supervisory authority designated under the ePrivacy Directive is solely competent to monitor compliance with the directive. However, IMY is the competent supervisory authority under the GDPR for processing that is not specifically regulated in the ePrivacy Directive.

4 Directive 2002/58/EC of the European Parliament and of the Council of July 12, 2002, on the processing of personal data and the protection of privacy in the electronic communications sector (Directive on privacy and electronic communications).

5 Opinion 5/2019 on the interaction between the Directive on privacy and electronic communications and the General Data Protection Regulation, particularly regarding the competence, tasks, and powers of data protection authorities, adopted on March 12, 2019, paragraphs 68 and 69.

Swedish Authority for Privacy Protection

Diary Number: IMY-2022-3270

7(16)

Date: 2024-08-29

IMY's Assessment

IMY's review aims at a situation where data subjects have used a service on the Pharmacy's website to order a product and have themselves provided the information captured by the Meta pixel. This information handling does not imply that data is stored in or retrieved from a subscriber's or user's terminal equipment and is thus not covered by Chapter 9, Section 28 of the Electronic Communications Act (LEK) or any previously applicable corresponding provision in the Electronic Communications Act. This means that the regulation in the General Data Protection Regulation (GDPR) is applicable to the relevant personal data processing and that IMY is the competent supervisory authority. Furthermore, it can be noted that IMY's review concerns whether the Pharmacy has taken sufficient security measures, which is not specifically regulated in the LEK. This circumstance also means that IMY is competent to investigate the issue that the supervisory matter pertains to.

Data Controller

Applicable Provisions

According to Article 4.7 of the GDPR, the data controller is the entity that alone or jointly with others determines the purposes and means of the processing of personal data. The fact that purposes and means can be determined by more than one actor means that multiple actors can be data controllers for the same processing.

The data controller shall, according to Article 5.2 of the GDPR, be responsible for and be able to demonstrate compliance with the principles in Article 5.1 (the principle of accountability).

IMY's Assessment

The Pharmacy has stated that the company is the data controller regarding the implementation of the

Meta pixel and the transfer of data that has occurred to Meta.

The investigation in the matter shows that the Pharmacy has implemented the Meta pixel, a script-based tool in the form of a code snippet that records visitors' actions and transfers the information to Meta, on its website and subsequently activated the AAM function. The purpose of the Meta pixel has been to increase the efficiency of the company's marketing and to some extent target advertisements to previous visitors to the website. The Pharmacy has thus determined how the processing should be carried out and for what purpose the personal data should be processed. IMY therefore assesses that the Pharmacy is the data controller for the processing of personal data that has occurred through the use of the Meta pixel with the AAM function activated.

Has the Pharmacy ensured an appropriate level of security for the personal data?

Applicable Provisions

The requirement to take appropriate protective measures

According to Article 32.1 of the GDPR, the data controller shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk of the processing. This shall, according to the same provision, be done taking into account the latest developments, the costs of implementation, and the nature, scope, context, and purposes of the processing as well as the risks, varying in likelihood and severity, to the rights and freedoms of natural persons. According to Article 32.1, appropriate protective measures include, where appropriate,

Swedish Authority for Privacy Protection

Diary Number: IMY-2022-3270

8(16)

Date: 2024-08-29

- a) pseudonymization and encryption of personal data,
- b) the ability to continuously ensure confidentiality, integrity, availability, and resilience of the processing systems and services,
- c) the ability to restore availability and access to personal data in a reasonable time in the event of a physical or technical incident, and
- d) a procedure for regularly testing, examining, and evaluating the effectiveness of the technical and organizational measures intended to ensure the security of processing.

In assessing the appropriate level of security, special consideration shall be given, according to Article 32.2, to the risks posed by the processing, particularly from accidental or unlawful destruction, loss, or alteration, or to unauthorized disclosure of or unauthorized access to the personal data that has been transmitted, stored, or otherwise processed.

Recital 75 of the General Data Protection Regulation states factors to be considered when assessing the risk to the rights and freedoms of natural persons. Among other things, it mentions the loss of confidentiality regarding personal data that is subject to confidentiality obligations, as well as whether the processing concerns data about health or sexual life. Furthermore, consideration should be given to whether the processing involves personal data about vulnerable natural persons, especially children, or whether the processing involves a large amount of personal data and concerns a large number of data subjects.

Recital 76 of the General Data Protection Regulation states that the likelihood and severity of the risk to the rights and freedoms of the data subject should be determined based on the nature, scope, context, and purposes of the processing. The risk should be assessed based on an objective evaluation, through which it is determined whether the data processing involves a risk or a high risk.

Processing of Sensitive Personal Data

Data concerning health and sexual life constitute special categories of personal data, so-called sensitive personal data, which are afforded a particularly strong protection under the General Data Protection Regulation. As a general rule, it is prohibited to process such personal data according to Article 9.1 of the General Data Protection Regulation, unless the processing falls under one of the exceptions in Article 9.2 of the Regulation.

Data concerning health is defined in Article 4.15 of the General Data Protection Regulation as personal data relating to the physical or mental health of a natural person, which provides information about that

person's health status. Recital 35 of the General Data Protection Regulation states that personal data concerning health should include all data related to a registered person's health condition that provides information about the registered person's past, present, or future physical or mental health status. The Court of Justice of the European Union in the Lindqvist case established that information about a person having injured their foot and being partially on sick leave constitutes personal data concerning health according to the Data Protection Directive (the directive was repealed by the General Data Protection Regulation). The Court stated in the case that, considering the purpose of the Data Protection Directive, the term "data concerning health" should be given a broad interpretation and is to be understood as encompassing data relating to all aspects of a person's health, both physical and mental. The Court has in the later ruling Vyriausioji tarnybinės etikos komisija

6 Directive 95/46/EC of the European Parliament and of the Council of 24 October 1995 on the protection of individuals with regard to the processing of personal data and on the free movement of such data.

7 Judgment of the Court of Justice of the European Union of 6 November 2003, Lindqvist, C-101/01, EU:C:2003:596, paragraphs 50–51.

Swedish Data Protection Authority

Case Number: IMY-2022-3270

Page 9 of 16

Date: 2024-08-29

It has been established that the concept of sensitive personal data according to Article 9.1 of the Data Protection Regulation should be interpreted broadly and assessed that even personal data that indirectly, through intellectual reasoning or verification, reveals a natural person's sexual orientation constitutes sensitive personal data under the relevant provision.

IMY's Assessment

The processing has involved a high risk and required a high level of protection.

The data controller must take measures to ensure a level of protection that is appropriate based on the risks associated with the processing. The assessment of an appropriate level of protection should be made with consideration of, among other things, the nature, scope, context, and purpose of the processing, as well as the risks, of varying degrees of probability and severity, to the rights and freedoms of natural persons.

IMY must initially determine which personal data the Pharmacy has transferred to Meta through the Meta pixel with the AAM function activated.

The investigation in the case shows that the activation of the Meta pixel's AAM function has meant that the Pharmacy, unless a customer has accepted marketing cookies and has not used an ad blocker, has transferred data about completed purchases to Meta. The data transferred has included information about purchased products (including the URL of products on the website, product ID, and product type) as well as contact information about the customer (including first and last name, address, and phone number).

The data transferred to Meta has not included prescription products, but has included the following products and product categories:

- a) self-tests and treatment for sexually transmitted diseases
- b) contraceptives and emergency contraceptive pills
- c) sex toys
- d) products for vaginal health (e.g., dry mucous membranes, menopausal symptoms, and yeast infections)
- e) products for prostate issues and urinary problems
- f) pregnancy tests, ovulation tests, and pregnancy products
- g) products for the treatment of fungal infections (e.g., athlete's foot or nail fungus)
- h) products for the treatment and control of diabetes
- i) products for the treatment of rectal issues (e.g., anal fissures and hemorrhoids)
- j) products for the treatment of stomach issues (e.g., IBS, constipation, and diarrhea)

- k) products for the treatment of migraines
- l) products for the treatment of allergies
- m) accessories for hearing aids
- n) products for the treatment of bacterial infections
- o) products for the treatment of psoriasis
- p) products for the treatment of rosacea
- q) ostomy products.

In the case, it has been revealed that Meta has implemented a so-called filtering mechanism aimed at detecting and deleting information transferred to Meta in violation of the company's policy. IMY has, for this reason, obtained information from Meta about how the filtering mechanism works. According to Meta's statement on February 16, 2024, it appears

8 Court of Justice of the European Union ruling of August 1, 2022, Vyriausioji tarnybinės etikos komisija, C-184/20, EU:C:2022:601, pp. 123–127.

Swedish Authority for Privacy Protection

Diary Number: IMY-2022-3270

10(16)

Date: 2024-08-29

that the mechanism is designed to detect and delete potentially unauthorized information, such as health and financial data, in the data that users of the pixel transmit to Meta before it is stored and used in Meta's advertising system. When such data is detected and deleted, the user receives a notification about it, but the filtering mechanism operates even if such a message is not sent to the user. In light of this, IMY notes that the pixel itself does not contain a filtering mechanism that prevents the transmission of data to Meta. The filtering mechanism is designed to filter out potentially privacy-sensitive data only after it has been transmitted to Meta and if Meta's system has been able to identify that the transmitted data contains such unauthorized information. The absence of notifications about unauthorized and deleted information cannot, in itself, be considered confirmation that potentially privacy-sensitive data has not been transmitted to Meta. The existence of the filtering function has, in summary, not prevented the established transmission of personal data to Meta.

IMY makes the following assessment of the risks associated with the current personal data processing. Processing that involves sensitive personal data generally entails higher risks. The concept of sensitive personal data should be interpreted broadly and also includes data that indirectly reveals such information. The pharmacy has transmitted data to Meta regarding which product a customer has purchased, as well as data that identifies the customer in the form of, among other things, name, address, and phone number. IMY believes that the combination of data transmitted to Meta has made it possible to deduce that a specific person has purchased a certain identified product.

The pharmacy has not transmitted data about prescription products. However, most of the products in the pharmacy's other assortment (see points a–q above) are of such a nature that information about a person purchasing such a product could reveal information about the individual's health condition or sexual life. The pharmacy has argued that it is not certain that the buyer is the actual user of the product, and it is difficult to categorically state that sensitive personal data has been transmitted.

However, IMY believes that it is likely that, in at least some cases, certain purchases of, for example, ostomy products, products for anal, urinary, and prostate issues, vaginal issues, as well as treatment of sexually transmitted diseases and diabetes, have been made for personal use in order to treat a specific health condition. Therefore, IMY assesses that it is likely that the processing has involved health data in the sense referred to in Article 4.15 of the General Data Protection Regulation.

IMY makes the same assessment regarding purchases of, for example, emergency contraceptive pills and sex toys, meaning that it is likely that the purchases in at least some cases have been made for personal use and that the processing has thus revealed information about the individual's sexual life. In assessing the appropriate level of protection, the pharmacy should therefore have considered that the processing could involve sensitive personal data.

IMY further assesses that data regarding purchases of the identified goods in points a–q, regardless of

whether the data constitutes sensitive personal data or not, are of such a privacy-sensitive nature that they require strong protection under the General Data Protection Regulation. It has also been indicated that the pharmacy, in some cases, has transmitted other protected personal data in the form of personal identification numbers.⁹ Furthermore, the processing has been carried out by a pharmacy where the customer can be assumed to have special expectations that their personal data will be handled with a high degree of confidentiality. IMY therefore concludes that both the nature of the personal data and the

⁹ Personal identification numbers are subject to special protection under Article 87 of the General Data Protection Regulation and Chapter 3, Section 10 of the Act (2018:218) with supplementary provisions to the EU's General Data Protection Regulation.

Swedish Authority for Privacy Protection

Case Number: IMY-2022-3270

11(16)

Date: 2024-08-29

The context in which they have been processed has resulted in increased risks to the rights and freedoms of the data subjects.

IMY also notes that the processing has been extensive. The pharmacy has had a large number of customers during the period when the AAM function of the Meta pixel was activated, and the company estimates that up to 930,000 individuals have been affected by the incident in question. The calculation is based on the number of online purchases during the relevant period, taking into account that a certain proportion of purchases were made by returning customers and by individuals using ad blockers or who have declined cookies. The pharmacy has also stated that 9 percent of the total online purchases made during the period involved the privacy-sensitive products listed under items a–q. IMY assesses that based on this information, even though it is not possible to determine exactly how many of these purchases were made by registered individuals who did not use ad blockers or declined marketing cookies, it can be established that the incident has affected a large number of registered individuals.

In summary, IMY assesses that the processing, considering its nature, scope, and context, has posed high risks that have resulted in a requirement for a high level of protection for personal data. The measures should, among other things, ensure that personal data is protected against unauthorized disclosure and loss of control.

The pharmacy has not implemented sufficient security measures

IMY will then assess whether the pharmacy has ensured the high level of protection required for personal data.

The pharmacy has stated that the company had proactive processes in place before the incident to ensure proper handling of personal data. However, in this case, established procedures for IT development and risk assessment, which include review and updating of information analyses for all changes to systems and tools, were not followed by individual employees. The investigation shows that the pharmacy therefore did not analyze the risks and consequences that the processing of personal data resulting from the implementation of the Meta pixel and the activation of the AAM function would entail before the processing began. The pharmacy also did not make a selection and categorization of which products would be processed. This has led to the fact that, aside from the exclusion of prescription items, there has been no technical limitation on which data would be included in the processing, and that privacy-sensitive data regarding, for example, purchases of over-the-counter medications and medical devices has been transferred to Meta.

A fundamental prerequisite for the pharmacy to fulfill its obligations under the General Data Protection Regulation is that the company is aware of what processing occurs under its responsibility. The pharmacy has, for a long period from January 19, 2020, when the AAM function was activated, until April 25, 2022, when the Meta pixel was removed, transferred more data than intended to Meta without discovering it themselves. The pharmacy has stated that the activation of the AAM function of the Meta pixel did not follow the pharmacy's regular procedures and that no desirable procedures for review and follow-up were therefore established. Since the pharmacy only had procedures for following up

documented changes, which were carried out according to established procedures, the pharmacy lacked the ability to detect and address other changes that were actually implemented or occurred in other ways. Against this background, IMY finds that the pharmacy has lacked organizational routines to systematically follow up on unintentional changes in its systems.

Swedish Authority for Privacy Protection

Case Number: IMY-2022-3270

12(16)

Date: 2024-08-29

IMY thus assesses that the Pharmacy, even considering what has been stated regarding the procedures that were in place at the time of the violation, cannot be considered to have taken appropriate technical and organizational measures in relation to the high risks that the processing has entailed. The Pharmacy has therefore processed personal data in violation of Article 32.1 of the General Data Protection Regulation.

Choice of Intervention

Applicable Provisions, etc.

In cases of violations of the General Data Protection Regulation, IMY has a number of corrective powers available under Article 58.2 of the General Data Protection Regulation. Article 58.2 of the General Data Protection Regulation states that IMY, in accordance with Article 83, shall impose administrative fines in addition to or instead of other corrective measures referred to in Article 58.2, depending on the circumstances of each individual case.

Each supervisory authority shall ensure that the imposition of administrative fines in each individual case is effective, proportionate, and dissuasive. This is stated in Article 83.1 of the General Data Protection Regulation.

Article 83.2 specifies the factors to be taken into account in determining whether an administrative fine should be imposed, as well as what should influence the amount of the fine. Relevant to the assessment of the seriousness of the violation are, among other things, its nature, severity, and duration. The EDPB has adopted guidelines on the calculation of administrative fines under the General Data Protection Regulation aimed at creating a harmonized method and principles for calculating fines.

According to Article 83.4, in cases of violations of, among other things, Article 32, administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, up to 2 percent of the total global annual turnover in the preceding financial year shall be imposed, depending on which value is higher.

If it concerns a minor violation, IMY may, as stated in Recital 148, instead of imposing a fine, issue a reprimand in accordance with Article 58.2 b of the Regulation.

IMY's Assessment

Administrative Fine to be Imposed

IMY has assessed that the Pharmacy has processed personal data in violation of Article 32.1 of the General Data Protection Regulation.

The violation has occurred by the Pharmacy processing personal data with an insufficient level of security, which has resulted in personal data of a privacy-sensitive and protectable nature concerning a large number of data subjects being inadvertently transferred to Meta. Unauthorized access to this type of data poses a high risk to the freedoms and rights of the data subjects. The transfer has been ongoing for a long time and was not discovered and addressed until the Pharmacy was informed of the deficiency by an external party.

IMY considers that this is not a minor violation that would warrant a reprimand instead of an administrative fine.

10 EDPB Guidelines 04/2022 on the calculation of administrative fines under the GDPR.

Integrity Protection Authority

The Court of Justice of the European Union has clarified that it is required for the data controller to have committed a violation intentionally or through negligence for administrative fines to be imposed under the General Data Protection Regulation (GDPR). The Court has stated that data controllers can be subject to fines for actions if they cannot be considered to have been unaware that the action constituted a violation, regardless of whether they were aware that they were disregarding the provisions of the GDPR.¹¹ According to the principle of accountability, which is expressed in Article 5.2 of the GDPR, the entity responsible for the processing of personal data must ensure and be able to demonstrate that the processing is in compliance with the GDPR. Thus, IMY finds that the Pharmacy is responsible for ensuring that the personal data processed in its operations is handled in a manner that ensures an appropriate level of security. IMY has determined in its assessment that the Pharmacy has not met the requirements set forth by the GDPR in this regard. The Pharmacy cannot be considered to have been unaware that its actions constituted a violation of the regulation.¹² IMY therefore assesses that the conditions for imposing an administrative fine on the Pharmacy for the violations are fulfilled. In determining the amount of the fine, IMY will consider the circumstances specified in Article 83.2 and ensure that the administrative fine is effective, proportionate, and dissuasive.

Basis for calculating the fine

IMY assesses that it is the annual turnover of the Pharmacy that should be used as the basis for calculating the administrative fines in this particular case.¹³ The maximum fine applicable to companies for violations of Article 32 amounts to the higher of 10,000,000 EUR or 2 percent of the total global annual turnover from the previous financial year.

According to the Pharmacy's annual report for the year 2023, the annual turnover for that year was 23,270,000,000 SEK. The highest fine that can be established in this case thus amounts to 2 percent of that amount, which is 465,400,000 SEK. IMY notes that there is no support in the applicable legislation for calculating the fine based on a different amount in the manner that the Pharmacy has suggested is done under other EU legal provisions.

Severity of the violation

According to the EDPB's guidelines, the supervisory authority must assess whether the violation is of low, medium, or high severity according to Article 83.2 a, b, and g of the GDPR.¹⁴

The current violation has involved a large number of registered individuals and has persisted over a long period. The data that has been transferred has included personal identification numbers and information about directly identifiable individuals who have purchased privacy-sensitive products.

¹¹ Judgment of the Court of Justice of the European Union on December 5, 2023, *Nacionalinis visuomenės sveikatos centras*, C-683/21, EU:C:2023:949, para. 81 and Judgment of the Court of Justice of the European Union on December 5, 2023, *Deutsche Wohnen SE* C-807/21, EU:C:2023:950, para. 76.

¹² See also the assessment of negligence in the Administrative Court of Appeal in Stockholm's judgment on March 11, 2024, in case 2829-23, p. 12.

¹³ The Pharmacy is the parent company of a group. If the company is subject to the obligation to prepare consolidated financial statements, these consolidated financial statements for the group's parent company are relevant to reflect the company's total turnover, see EDPB's guidelines Guidelines 04/2022 on the calculation of administrative fines under the GDPR, point 130.

¹⁴ EDPB's guidelines Guidelines 04/2022 on the calculation of administrative fines under the GDPR, point 60.

Swedish Authority for Privacy Protection

Reference Number: IMY-2022-3270

The unauthorized transfer has thus posed a high risk to the rights and freedoms of the data subjects in the form of a risk of loss of confidentiality for sensitive information. Furthermore, the violation occurred in a pharmacy operation where the data subjects must be considered to have had a legitimate expectation of high confidentiality and that their personal data would not be disclosed to unauthorized parties. The sale of over-the-counter and other health-related products must also be considered part of the core operations of the pharmacy, which makes the violation more serious than if that were not the case.

In assessing the severity of the violation, IMY also takes into account that the pharmacy had implemented a number of appropriate technical and organizational security measures at the time of the violation. Furthermore, the personal data was transferred in a hashed, that is, unreadable, format to a single recipient, and thus it does not involve uncontrolled disclosure where the data, for example, has been shared with many unauthorized parties or has been publicly available on the web.

IMY assesses, in light of the above circumstances, that it overall constitutes a violation of Article 32.1 of the Data Protection Regulation of low severity.

In determining the amount of the administrative fine, IMY shall also take into account aggravating and mitigating factors as listed in Article 83.2 of the Data Protection Regulation. After the violation, the pharmacy has, among other things, engaged in a dialogue with Meta regarding deletion, provided information to the data subjects, and taken measures to reduce the risk of similar incidents in the long term. However, IMY notes that the measures were taken only after the pharmacy was made aware of the existing deficiencies by an external party and that they cannot be considered to go beyond what is expected of the pharmacy in the current case. The measures taken are therefore not factors that influence IMY's assessment of the size of the administrative fine in a mitigating direction. The same applies to the fact that the pharmacy submitted a report of the personal data incident and cooperated with IMY in the investigation of the current violation, as these circumstances should be considered neutral in determining the administrative fine.

IMY notes that no other circumstances have emerged that affect IMY's assessment of the size of the administrative fine in an aggravating or mitigating direction.

The administrative fine shall be effective, proportionate, and deterrent

The administrative fine shall be effective, proportionate, and deterrent. This means that the amount must be determined so that the administrative fine leads to rectification, provides a preventive effect, and is also proportionate in relation to both the current violation and the financial capacity of the supervisory subject.

IMY determines, based on a comprehensive assessment, that the pharmacy shall pay an administrative fine of 37,000,000 SEK. IMY assesses that this amount is effective, proportionate, and deterrent.

15 The more central a processing is to the data controller's operations, the more serious the inaccuracies in the processing become. See EDPB's guidelines Guidelines 04/2022 on the calculation of administrative fines under the GDPR, point 53.

16 EDPB's guidelines Guidelines 04/2022 on the calculation of administrative fines under the GDPR, points 95–98.

Swedish Authority for Privacy Protection

Reference Number: IMY-2022-3270

15(16)

Date: 2024-08-29

This decision has been made by the acting Director General David Törnngren after presentation by the lawyer Maja Welander. In the final processing, the acting Chief Legal Officer Cecilia Agnehall, the unit manager Nidia Nordenström, the lawyer Shirin Daneshgari Nejad, and the IT and information security specialist Petter Flink have also participated.

David Törngren, 2024-08-29 (This is an electronic signature)

Attachment

Information on payment of the administrative fine

Copy to

Data Protection Officer for the Pharmacy

Swedish Authority for Privacy Protection

Reference Number: IMY-2022-3270

16(16)

Date: 2024-08-29

How to appeal

If you wish to appeal the decision, you must write to IMY. Indicate in the letter which decision you are appealing and the change you are requesting. The appeal must be received by IMY no later than three weeks from the day you were notified of the decision. However, if you are a party representing the public interest, the appeal must be submitted within three weeks from the day the decision was announced. If the appeal has been submitted in time, IMY will forward it to the Administrative Court in Stockholm for examination.

You may email the appeal to IMY if it does not contain any sensitive personal data or information that may be subject to confidentiality. The authority's contact details are provided on the first page of the decision.